

1. A financial technology company in Charlotte, North Carolina authorizes a controlled red team engagement to evaluate defensive monitoring within its Windows server environment. During testing, the team executes a series of scripted administrative commands through the native automation shell. The security controls initially prevent the activity from completing. The tester then modifies how the command content is expressed while preserving its original functionality. After this adjustment, the same administrative operations execute successfully without triggering the operating system's integrated content inspection mechanism. Which technique was most likely used to bypass the Windows Antimalware Scan Interface (AMSI)?

- Obfuscation
- Memory Hijacking
- PowerShell Downgrade
- Forcing an Error

2. Ethan works as a penetration tester at CyberGuard Solutions, a cybersecurity consulting firm in Raleigh, North Carolina. During an authorized security assessment of a regional insurance company, Ethan was provided with a set of password hashes to evaluate the strength of employee-generated credentials. To test resistance against word-based password creation patterns, Ethan supplied a single custom wordlist containing common organizational terms and department names into his cracking tool. The tool automatically generated password candidates by linking multiple entries from that same list in varying combinations before attempting to match them against the hashes. This approach proved highly effective against passwords formed by concatenating familiar words. Which of the following password-cracking techniques is Ethan using?

- Markov-Chain Attack
- PRINCE Attack
- Combinator Attack
- Fingerprint Attack

3. A digital publishing firm in Charlotte, North Carolina, noticed suspicious probing activity against its public website. To proactively assess exposure, the security team initiated a focused scan of the company's HTTP servers. The chosen tool examined server headers, identified installed web server software through file signatures and favicon analysis, checked for outdated components, and searched for potentially dangerous files and misconfigurations. The scan also supported SSL connections and generated exportable reports in multiple formats for documentation. Which vulnerability assessment tool most closely aligns with the capabilities described?

- OpenVAS
- Nessus
- Qualys VM
- Nikto

4. Prior to a federal audit, a cybersecurity consulting firm conducted an exposure review for a software company in Salt Lake City, Utah. The engagement focused on evaluating infrastructure reachable through the organization's publicly registered domain records. The consultants identified open service ports on several servers, examined their patch levels for outdated components, and reviewed available DNS zone information to understand how systems were presented to remote systems. Based on the activities described, what type of vulnerability scanning is being performed?

- Network-based Scanning
- Internal Scanning
- Manual Scanning
- External Scanning

5. A manufacturing company in Columbus, Ohio, reported a surge in internal support tickets after employees received an alarming email appearing to originate from an independent cybersecurity researcher. The message claimed that a newly discovered malware strain was actively targeting corporate email

systems and stated that several Fortune 500 organizations had already been compromised. It encouraged recipients to immediately circulate the message within their departments "to minimize exposure," warning that failure to act quickly could result in data loss. The email did not request credentials, payment, or direct downloads. However, it relied heavily on dramatic language and cited unverifiable statistics to increase urgency and credibility. From a social engineering classification standpoint, how should this technique be categorized?

- Hoax Letters that spread false security warnings
- Spam Email used for mass unsolicited distribution
- Chain Letters that incentivize forwarding messages
- Scareware designed to trick users into installing rogue software

6. While simulating a reconnaissance phase against a cloud-hosted retail application, your team attempts to gather DNS records to map the infrastructure. You avoid brute-forcing subdomains and instead aim to collect specific details such as the domain's mail server, authoritative name servers, and potential administrative information like serial number and refresh interval. Given these goals, which DNS record type should you query to extract both administrative and technical metadata about the target zone?

- MX
- TXT
- NS
- SOA

7. A competing technology firm begins releasing products that closely mirror the design, pricing strategy, and feature roadmap of ApexDynamics Inc. An internal review reveals that detailed information about ApexDynamics' upcoming initiatives had been gradually collected through publicly available sources and external disclosures before product launch. Which footprinting-related threat does this scenario best represent?

- Business Loss
- Corporate Espionage
- Social Engineering
- Information Leakage

8. A multinational manufacturing company in San Jose, California has deployed a perimeter firewall to protect its internal production networks. During a red team exercise, testers observe that the device monitors active TCP communications and allows traffic to continue only when packets correspond to recognized, previously established connections. The firewall evaluates multiple header attributes across ongoing communications while operating inline at the network boundary. From a firewall architecture perspective, what type of Firewall is most likely in use at this perimeter?

- Circuit-Level Gateway Firewall
- Stateful Multilayer Inspection Firewall
- Packet Filtering Firewall
- Application-Level Firewall

9. A cloud service provider in Singapore is refining its defensive monitoring strategy to identify large-scale denial-of-service attempts against hosted applications. The security engineering team wants a detection mechanism that continuously evaluates incoming traffic streams and statistically determines the exact moment when normal behavior shifts into anomalous activity. Rather than relying solely on static baselines or historical comparisons, the team prefers an approach that detects abrupt deviations in real time by identifying structural breaks in traffic metrics as they occur. Which DDoS detection technique best fits this requirement?

- Sequential Change-Point Detection
- Activity Profiling
- Traffic Pattern Analysis

- Wavelet-Based Signal Analysis

10. A municipal data center in Phoenix, Arizona, deploys a network intrusion detection system to monitor traffic entering its public records portal. During a scheduled red team exercise, authorized testers successfully exploit a vulnerable web service and gain restricted administrative access. Post-exercise review reveals that the IDS generated a high-severity alert precisely at the time the exploit traffic reached the server. Log correlation confirms that the alert corresponded directly to the malicious activity performed during the test window. How should this IDS outcome be classified?

- True Positive
- False Positive
- True Negative
- False Negative

11. You are part of the red team assigned to evaluate the physical and social vulnerabilities of a government contractor's office located in a metropolitan business hub. During your pretexting phase, you decide to simulate the role of a third-party IT technician. Upon arrival, the receptionist allows you entry without verification, assuming you're there for scheduled printer maintenance. While moving through the workspace, you casually observe open terminals, unattended printouts, and discarded sticky notes at workstations. You later report several user credentials and partial access details acquired during this visit. Which social engineering technique does this scenario best illustrate?

- Shoulder Surfing
- Impersonation
- Dumpster Diving
- Eavesdropping

12. A regional e-commerce company in Dallas, Texas operates an Apache-based web server to manage product catalogs and promotional campaigns. During an authorized assessment, a security consultant analyzes how the platform

processes a referral parameter embedded in product-sharing links. While reviewing responses through an intercepting proxy, he observes that values supplied in the referral parameter are incorporated into metadata returned to the browser. By introducing carefully crafted delimiter characters into the parameter, he notices that the structure of the server's outbound response changes in an unexpected manner. Further testing shows that the manipulated input causes the server to generate multiple logically distinct response segments within what should have been a single transaction. When the crafted link is accessed through a standard browser, the client interprets the injected portion as a separate directive, resulting in redirection behavior influenced by the attacker-controlled input. Identify the web server attack technique being demonstrated in this scenario.

- Web Cache Poisoning Attack
- HTTP Response-Splitting Attack
- Frontjacking Attack
- Directory Traversal Attack

13. The various hping commands are as follows. During an authorized penetration test, a security analyst executes a TCP-based probe using hping without attempting to complete the three-way handshake. Packet analysis shows that closed ports return a TCP RST response, while open ports do not generate any reply. The crafted packets contain a non-standard combination of TCP control bits rather than relying on a single control flag. Which scanning technique is being performed?

- FIN, PUSH and URG scan on port 80
- ICMP ping
- UDP scan on port 80
- ACK scan on port 80

14. A health-tech startup in Raleigh, North Carolina operates a Kubernetes cluster supporting patient-facing microservices. During an authorized security

assessment, a certified ethical hacker reviews internal cluster activity records available to operations personnel. While analyzing these records, the tester notices that authentication artifacts associated with service accounts are recorded within system-generated output. The tester determines that if an individual obtained access to these records, they could reuse the captured authentication material to interact with cluster resources under the same privileges. Which Kubernetes vulnerability best corresponds to this condition?

- No Non-repudiation
- Unauthenticated HTTPS Connections
- No Certificate Revocation
- Exposed Bearer Tokens in Logs

15. A cybersecurity team at a cloud infrastructure provider in San Jose, California, initiated a structured vulnerability evaluation across its production environment. The scanning process began by identifying communication protocols active on each host. Once the protocols were cataloged, the platform analyzed which services were associated with those ports and dynamically selected only the vulnerability tests relevant to those detected services. The scanning logic adjusted automatically based on discoveries made during execution. Which vulnerability assessment approach is illustrated in this scenario?

- Tree-Based Assessment
- Product-Based Solutions
- Service-Based Solutions
- Inference-Based Assessment

16. During a forensic log review at a satellite communications provider in Denver, Colorado, cybersecurity analyst Kevin Morales identified subtle timestamp irregularities in archived telemetry records. Although the discrepancies were minor, regulatory reporting standards required confirmation that the system clock was synchronizing correctly with its configured time sources. Kevin needed

to interact directly with the host's running time service to review its current associations and operational state. He was not attempting to reset the clock or trace the hierarchy of upstream time authorities, but rather to query the active service for detailed status information from the target machine. Identify the command Kevin should execute to obtain this information.

- `ntptrace [-n] [-m maxhosts] [servername/IP_address]`
- `ntpq [-inp] [-c command] [host] [...]`
- `ntpd -i [ilnps] [-c command] [host] [...]`
- `ntpq -p [host]`

17. A financial technology firm in Atlanta, Georgia launches an internal investigation after multiple employees report that a popular messaging application on their Android devices has begun displaying excessive advertisements and behaving unpredictably. Security analysts discover that users had installed a utility application from a third-party marketplace weeks earlier. Further examination shows that this application silently replaced certain legitimate apps already present on the device. The compromised applications were then used to generate large volumes of advertisements and collect user data for external transmission. Based on the observed behavior, what malware is most consistent with this incident?

- Mamont
- Agent Smith
- Pegasus
- GoldPickaxe

18. A retail brand based in San Diego, California, authorized a controlled mobile security exercise to evaluate risks associated with third-party application distribution channels. Testers acquired a version of the company's customer rewards application from an unofficial marketplace frequently used by overseas customers. The application's visual layout and functionality were indistinguishable from the officially released version available in mainstream

app stores. Behavioral monitoring conducted in a sandbox environment revealed that, in addition to its normal operations, the application initiated outbound connections unrelated to its documented features. A binary comparison against the vendor-supplied build confirmed structural differences between the two versions. What mobile-based social engineering technique does this scenario most accurately represent?

- Repackaging Legitimate Apps after modifying their internal structure
- Deploying Fake Security Applications disguised as protection tools
- Publishing Malicious Apps designed to mimic trusted brands
- Conducting SMiShing campaigns through fraudulent text messages

19. A university authorizes a wireless protocol resilience assessment on its WPA2-secured network. An ethical hacker positions a testing device within range of an access point and observes the key negotiation exchange between the client and the access point. By selectively retransmitting a previously captured handshake message at a precise moment in the exchange, the tester causes the client device to reinstall an already negotiated encryption key. Subsequent traffic patterns reveal that certain protections expected from unique session parameters are no longer consistently enforced. What kind of wireless attack technique is being illustrated in this scenario.

- Man-in-the-Middle Attack
- Key Reinstallation Attack (KRACK)
- Replay Attack
- WPA2 PSK Offline Cracking

20. At a smart grid development company in Portland, Oregon, analysts isolated several infected executable files from different endpoints. Each infected file demonstrated the same payload behavior, including registry persistence and outbound communication attempts. However, binary comparison revealed that no consistent decryptor routines, recurring code segments, or stable structural patterns could be traced between the samples. Although the operational intent

remained unchanged, the internal composition of each infection appeared uniquely reconstructed. Determine the virus subtype that most accurately matches this behavior.

- Logic Bomb Virus
- Polymorphic Virus
- Metamorphic Virus
- Sparse Infector Virus

21. A publicly traded blockchain startup conducts a forensic review after irregular transaction reversals are detected on its distributed ledger platform. Network telemetry indicates that a single coordinated entity controlled a dominant share of the computational power participating in block validation during the affected time window. As a result, certain confirmed transactions were replaced with alternate versions, enabling double-spending before the broader network regained balance. No individual node isolation or transaction front-running behavior is observed rather, the anomaly stems from disproportionate influence over block creation. Identify the blockchain attack most consistent with this incident.

- DeFi Sandwich Attack
- Eclipse Attack
- Finney Attack
- 51% Attack

22. A defense contractor in Arlington, Virginia, initiated an internal awareness exercise to test employee susceptibility to human-based manipulation. During the assessment, an individual posing as an external recruitment consultant began casually engaging several engineers at a nearby industry networking event. Over multiple conversations, the individual gradually steered discussions toward current research initiatives, development timelines, and internal project code names. No direct requests for credentials or system access were made. Instead, the information was obtained incrementally through carefully crafted

questions embedded within informal dialogue. Which social engineering technique is most accurately demonstrated in this scenario?

- Elicitation
- Baiting
- Quid Pro Quo
- Honey Trap

23. A national logistics company in Atlanta, Georgia maintains a segmented research VLAN inside its primary data center to study emerging supply-chain targeting tactics. The environment includes enterprise-grade server platforms hosting web applications, database services populated with curated operational data, and identity services configured to resemble production access structures. During a red team engagement, external adversaries who gained initial access were observed interacting with systems inside this VLAN for several days. They escalated privileges, accessed structured data repositories, moved between internal hosts, and attempted to reach additional internal segments. All activity occurred within the controlled environment and was instrumented to capture attacker techniques in depth. Which honeypot deployment model most accurately describes this research environment?

- Pure Honeypot
- Medium-interaction Honeypot
- Low-interaction Honeypot
- High-interaction Honeypot

24. An enterprise collaboration platform used by a pharmaceutical distributor in Boston, Massachusetts relies on a centralized identity store to validate employee credentials. While reviewing the authentication workflow, a security tester notices that user-provided values are directly embedded into backend lookup expressions responsible for locating account records. When specific logical operators and wildcard characters are introduced into the username field, the application's record-matching behavior changes. Instead of evaluating

a single identity entry, the backend process begins matching a broader set of records than intended, altering the outcome of the authentication check. The issue arises from improper handling of input within directory-based search logic. From the following options, identify the injection technique illustrated in this scenario.

- OS Command Injection
- LDAP Injection
- XPath Injection
- SQL Injection

25. A regional investment firm in Denver, Colorado, recently migrated to a fully switched Ethernet infrastructure. During an authorized security evaluation, a consultant connected a test device to an access-layer switch and initiated a scripted network interaction. Within minutes, administrators observed irregular switching behavior. Frames that were normally delivered directly between specific workstations began appearing across multiple switch ports. Users reported brief connectivity instability, but no configuration changes were made to the switch. After the activity subsided, forwarding operations gradually stabilized. Based on the observed behavior, which sniffing technique was most likely performed?

- Switch Port Stealing
- ARP Poisoning
- DNS Poisoning
- MAC Flooding

26. An energy infrastructure company in Tulsa, Oklahoma initiated a controlled phishing simulation targeting multiple operational departments. The test email claimed to originate from the corporate compliance office and instructed employees to "complete a mandatory regulatory update within the next 30 minutes to avoid account suspension." The message used a broad salutation instead of employee names and lacked the standard corporate signature footer

normally appended to official communications. Additionally, security analysts observed that the embedded hyperlink displayed the organization's domain in the message body; however, when examined more closely, the actual destination resolved to a shortened external URL redirecting to an unrelated host. From a defensive analysis standpoint, which indicator provides the strongest technical validation that the message is malicious?

- Presence of aggressive Urgency Language
- Absence of a formal corporate Missing Signature
- Use of Generic Greetings rather than individualized addressing
- Identification of Hover Mismatch URLs in the embedded link

27. A healthcare technology company deploys internet-connected cardiac monitoring devices across several hospitals in Minneapolis, Minnesota. During a controlled security review, an analyst discovers that administrative configuration features can be accessed remotely through components that interact with external management platforms. Further analysis reveals that these externally reachable components process user-supplied data without sufficient validation checks. Additionally, authentication controls protecting remote configuration features rely solely on basic credential verification without additional safeguards against automated misuse. According to the OWASP Top 10 IoT Vulnerabilities, how should this weakness be classified?

- Insecure Default Settings
- Insecure Network Services
- Lack of Device Management
- Insecure Ecosystem Interfaces

28. MidWest BioAnalytics, a pharmaceutical research firm in Columbus, Ohio, authorizes a controlled adversarial simulation to assess the resilience of its internal web-based inventory management platform. During the exercise, administrators observe that several active client connections briefly lose synchronization, and unexpected command patterns appear within system

transaction logs. The irregularities are subtle and become apparent only after reviewing stored network captures. Executive leadership requests a solution that can maintain ongoing visibility into network exchanges and highlight activity that diverges from typical communication behavior across the organization's infrastructure. Which approach best satisfies this requirement?

- Evaluate authentication token generation patterns
- Use an Intrusion Detection System (IDS)
- Monitor for abnormal surges of repeated ACK responses
- Perform manual packet inspection using a protocol analyzer

29. Following a suspected data breach at a pharmaceutical research lab in Cambridge, Massachusetts, forensic examiners identified several research documents that had been removed from normal directory listings on a compromised server. When analysts examined the physical storage sectors previously associated with those files, they found that the sector contents no longer matched the historical allocation records, and no recognizable fragments of the original material could be reconstructed. The disk structure itself remained intact, and the storage medium showed no signs of hardware-level destruction. Which anti-forensics technique best explains the attacker's actions in this scenario?

- Overwriting data/metadata
- Data/file deletion
- Artifact wiping
- Data hiding in file system structures

30. A regional logistics provider in Charlotte, North Carolina operates its shipment tracking and partner API services on an Apache web platform configured to support a modern multiplexed communication protocol to improve efficiency under concurrent load. During a controlled stress assessment, testers simulate sustained client activity that repeatedly initiates and completes numerous lightweight exchanges over persistent connections. Over time, system

monitoring reveals that memory utilization steadily increases despite stable request volume and no proportional rise in active sessions. Even after the simulated clients disconnect normally, resource usage does not return to baseline baseline levels. After several cycles, the service becomes sluggish and must be restarted to restore normal responsiveness. No unusual disk activity or database errors are observed during the test window. The behavior is only present when the multiplexed protocol mode is enabled; reverting to legacy handling eliminates the issue. Which Apache vulnerability best explains this behavior?

- mod_macro Buffer Over-read
- Insecure Default Configuration
- DoS in HTTP/2 with Initial Window Size O
- HTTP/2 Stream Memory Not Reclaimed on RST

31. A technology consulting firm in Denver, Colorado, recently experienced a wave of suspicious account compromise incidents. Several employees reported receiving an email that appeared identical to a legitimate cloud storage notification they had received earlier that week. The message reused the original branding, formatting, sender display name, and subject line. However, it informed recipients that the previously shared document had been "updated due to synchronization errors" and instructed them to reauthenticate using the embedded link. The link directed users to a convincing replica of the organization's authentication portal. Investigation revealed that the attacker had reused content from a genuine prior communication and modified only the embedded hyperlink. Which type of social engineering attack does this scenario most accurately represent?

- Clone Phishing
- Tabnabbing
- Consent Phishing
- Search Engine Phishing

32. During a red team simulation at Dominion Energy Analytics in Richmond, Virginia, an assessor crafts a malicious document containing embedded code designed to take advantage of a known application weakness. After transmitting the document to a targeted employee, the embedded code executes successfully when the file is opened. Immediately following successful code execution, the compromised workstation begins initiating outbound connections to a remote system controlled by the red team, allowing instructions to be issued and data to be exchanged. Within the Cyber Kill Chain methodology, which stage does the establishment of this remote communication channel represent?

- Exploitation
- Installation
- Command and Control
- Actions on Objectives

33. A multinational healthcare provider headquartered in Boston, Massachusetts relies on federated authentication to allow employees to access multiple cloud-hosted applications using a single sign-on portal. During an authorized red team engagement, a security consultant gains access to the organization's identity infrastructure and extracts signing material used in trust relationships between the internal identity provider and external cloud services. Using this material, the consultant generates authentication responses that grant administrative-level access to several cloud applications without interacting with user credentials or triggering multifactor authentication challenges. The access appears legitimate within the cloud service logs. Which cloud attack technique best aligns with this behavior?

- Cloud Hopper Attack
- Living off the Cloud (LotC) Attack
- Golden SAML Attack
- Man-in-the-Cloud (MITC) Attack

34. A U.S.-based online securities trading firm in New York is reviewing its

transaction authentication process. The security team confirms that each transaction is processed by first generating a hash of the transaction data. The hash value is then signed using the sender's private key. During verification, the recipient uses the corresponding public key to validate the signature before approving the transaction. The system documentation specifies that the same algorithm supports encryption, digital signatures, and key exchange mechanisms within the organization's secure communications infrastructure. Which encryption algorithm is being used in this implementation?

- RSA
- DSA
- Diffie-Hellman
- ElGamal

35. A DevOps engineer at a Toronto-based SaaS provider deploys a multi-tenant application within a shared orchestration environment. During a security assessment, a penetration tester discovers that a compromised workload is able to access host-level system resources and interact with adjacent workloads beyond its intended isolation controls. Further investigation reveals that the workload was launched with elevated privileges and insufficient runtime restrictions, allowing the attacker to cross the intended isolation boundary and gain unauthorized access to the underlying infrastructure. Which cloud attack technique best describes this security weakness?

- Man-in-the-Cloud Attack
- Container Escape
- Golden SAML Attack
- Side-Channel Attack

36. During a strategic security briefing at Meridian Global Analytics in Washington, D.C., executives review a series of coordinated activities targeting national infrastructure. These activities include manipulating digital media to influence public perception, disrupting communication networks, and degrading

critical systems to weaken institutional stability without direct conventional military engagement. What form of conflict best describes this type of coordinated activity?

- Information warfare
- Cyber espionage
- Cyberterrorism
- Hacktivism

37. At a digital marketing firm in Atlanta, Georgia, employees began reporting that access to a widely used cloud collaboration portal was intermittently redirecting them to a counterfeit interface hosted on an unfamiliar IP address. Security engineers observed that when multiple users across different departments attempted to access the legitimate domain, they consistently received the same incorrect IP resolution. The anomalous behavior persisted across sessions and affected numerous internal clients until the organization's name resolution service was restarted, after which normal resolution resumed. What DNS manipulation technique best explains this scenario?

- Conducting Internet DNS Spoofing from a remote network
- Injecting malicious records through DNS Cache Poisoning
- Executing Proxy Server DNS Poisoning to alter resolution paths
- Performing Intranet DNS Spoofing within the local network

38. A multinational payment processor conducts a long-term risk assessment to evaluate the durability of its encrypted archives against future computational advances. Internal analysts warn that if large-scale quantum computers become operational, currently deployed public-key schemes protecting stored customer data may become vulnerable to rapid key recovery. To maintain long-term confidentiality of archived financial records, the security architecture team must implement a defensive strategy that directly addresses cryptographic resilience rather than relying solely on network segmentation or development policy controls. Determine the most appropriate mitigation to protect stored data

against quantum-enabled decryption capabilities.

- Encrypt stored data with quantum-resistant algorithms
- Use quantum-specific firewalls to protect quantum communication channels
- Break data into fragments and distribute it across multiple locations
- Include quantum-resistance checks in SDLC and code review processes

39. An ethical hacker conducting an authorized assessment of a multinational advisory firm begins collecting intelligence exclusively from publicly accessible online platforms where employees share professional background details and engage in industry-related discussions. By correlating individual role descriptions, publicly endorsed technical competencies, collaborative conversations referencing internal initiatives, and recurring terminology used to describe projects and departments, the tester develops a structured view of reporting relationships, identifies commonly deployed technologies, and infers internal naming conventions. From a reconnaissance methodology perspective, which technique is being applied?

- Footprinting through Internet Research Services
- Footprinting through Social Networking Sites
- Footprinting through Social Engineering
- Footprinting through Search Engines

40. Justin Fletcher is conducting an authorized assessment for EverSafe Technologies in Las Vegas. During the active reconnaissance phase, he interacts directly with the organization's infrastructure to retrieve structural details about how its public-facing systems are logically organized. His activity generates entries within the target environment's monitoring systems. Which type of active footprinting technique is Justin performing?

- DNS interrogation
- Network/port scanning

- Social engineering
- User and service enumeration

41. During a targeted intrusion against a cloud infrastructure company in Salt Lake City, Utah, an attacker distributes a modified installation package of a legitimate network diagnostic utility widely used by employees. Before distributing the package, the attacker binds a malicious remote-access payload with the original executable so that both components are installed together. When users launch the diagnostic tool, it performs its normal troubleshooting functions, while the hidden payload simultaneously executes in the background and establishes communication with a remote command server. From a malware deployment perspective, what technique best describes this approach?

- Wrapper
- Packer
- Dropper
- Downloader

42. During an external assessment, a security analyst configures Nmap so that the hardware address recorded in firewall logs differs from the original interface address of the scanning system. Repeated executions of the scan show that the recorded hardware address changes automatically each time. What Nmap option enables this behavior?

- --spoof-mac 0
- --spoof-mac 00:01:02:25:56:AE
- --spoof-mac Dell
- --spoof-mac Dell 10.10.1.11

43. A cloud storage provider discovers that an unauthorized party obtained a complete backup of encrypted database files containing archived client communications. The attacker did not compromise the encryption keys, nor is there evidence that any original plaintext records were exposed. A forensic

cryptography specialist reviewing the breach considers the possibility that the adversary is attempting to analyze the encrypted data in isolation, searching for statistical irregularities or structural repetition within the encrypted output to infer meaningful information. To properly assess the organization's exposure, the specialist must determine which cryptanalytic approach best matches an attack conducted using only the intercepted encrypted data.

- Chosen-plaintext attack
- Known-plaintext attack
- Chosen-ciphertext attack
- Ciphertext-only attack

44. During an authorized security assessment at a municipal power distribution facility in Omaha, Nebraska, a certified ethical hacker performs passive traffic analysis between the control center and several remote substations. The tester observes structured request-response messages used to read coil status and write register values on industrial controllers. All communication occurs over TCP port 502, and the protocol does not provide built-in encryption or authentication. Based on these characteristics, which OT communication protocol is operating within this environment?

- IEC 60870-5-104
- OPC UA
- DNP3
- MODBUS

45. During an authorized engagement at IronClad Financial Services in Charlotte, the red team successfully exploits a weakness and obtains administrative access to a critical server. After achieving this objective, the team installs a backdoor mechanism to ensure continued access even if the original vulnerability is remediated. The team documents this activity as part of demonstrating long-term adversary behavior within the approved scope. Within the CEH ethical hacking framework, which phase does this activity represent?

- Reconnaissance
- Vulnerability Scanning
- Maintaining Access
- Clearing Tracks

46. During a scheduled red team engagement at a regional investment firm in Phoenix, Arizona, security consultants were permitted limited after-hours access to employee workstations. As part of the evaluation, a small intermediary device was placed inline between a keyboard and its connected desktop system. Over time, the device began forwarding captured keystroke activity through the company's established wireless environment, allowing the assessment team to collect periodic log data without interacting further with the workstation. What type of keylogger does this scenario describe?

- Hardware Keylogger
- Wi-Fi Keylogger
- Acoustic/CAM Keylogger
- Bluetooth Keylogger

47. An enterprise logistics company in Nashville, Tennessee recently rolled out an automation update across its internal administrative systems. Within days, performance monitoring tools began reporting sporadic spikes in outbound connections and short-lived execution chains tied to a built-in scripting utility. Security teams conducted full disk scans and integrity checks but found no unfamiliar executables or altered application binaries. Closer inspection of live system activity revealed that encoded command sequences were being executed within trusted system processes. The activity ceased after a restart but reappeared when similar administrative actions were triggered. Identify the malware category that best aligns with this operational pattern.

- Fileless Malware
- Rootkit
- Worm

- Trojan

48. At HarborGrid Utilities in Oregon, a security assessment team is reviewing how the organization's network monitoring platform evaluates inbound traffic targeting its SCADA management interface. During testing, the red team introduces carefully crafted packets that adhere to known protocol standards but contain payload sequences previously identified in documented exploit repositories. The monitoring system immediately flags the activity because it matches patterns stored in its internal threat database. However, when the team slightly modifies the exploit sequence while preserving its overall malicious intent, the alerts are no longer triggered. Based on this behavior, which intrusion detection is most likely deployed in this environment?

- Signature Recognition
- Anomaly Detection
- Stateful Protocol Analysis
- Protocol Anomaly Detection

49. During an authorized security assessment for a regional transportation authority in Sacramento, California, an ethical hacker is tasked with evaluating externally exposed web service interfaces used to exchange scheduling data with third-party transit applications. As part of the engagement, the ethical hacker retrieves publicly accessible service description files and systematically analyzes them to understand the operations supported by the service. By reviewing these definitions, the tester identifies undocumented methods, expected input parameters, and response schemas that were not clearly outlined in the public integration documentation. The activity provides a detailed understanding of the service's available capabilities before deeper testing begins. From the options below, identify the web service attack technique demonstrated in this scenario.

- SOAP Injection
- Application Logic Attacks
- XML Injection

- WSDL Probing Attacks

50. A financial analytics platform in Newark, New Jersey exposes a search parameter used to filter archived transaction records. During controlled testing, a security consultant submits carefully structured input designed to influence how the backend evaluates filtering conditions. The application continues to render the standard page layout, but response times fluctuate noticeably when specific logical expressions are introduced. By refining those conditions incrementally, the consultant observes consistent timing differences that align with changes in database evaluation behavior. The visible output remains unchanged, yet measurable performance variations provide feedback to the tester. Identify the SQL injection technique being demonstrated.

- Executing Out-of-Band SQL Injection via database-initiated HTTP requests
- Using HTTP Parameter Fragmentation to bypass firewall filtering
- Performing Heavy Query-Based Blind SQL Injection
- Applying Hex Encoding Evasion to obfuscate SQL keywords

51. A regional insurance claims platform in Sacramento, California is protected by a web application firewall that evaluates inbound requests for suspicious query structures. During an authorized assessment, a tester observes that conventional injection attempts are consistently rejected. The tester then adjusts the format and composition of the request while preserving its intended database behavior. After this modification, the request passes through the filtering mechanism and is processed by the backend system without disruption. Which firewall evasion technique is being demonstrated?

- Transforming query structure to evade pattern-based inspection
- Splitting payload components using HTTP Parameter Fragmentation (HPF)
- Combining multiple evasion methods through an integration approach
- Using HTTP Parameter Pollution (HPP) to override query parameters

52. At Redwood Financial Group in Boston, Massachusetts, the security

leadership team is formalizing a continual security strategy composed of four coordinated activities. During implementation planning, one team is assigned responsibility for reviewing operational data across the enterprise environment to recognize irregular patterns that may indicate malicious activity. Within this model, which activity is responsible for this responsibility?

- Detect
- Predict
- Respond
- Protect

53. During a red team assessment of a mid-sized insurance provider in Denver, Colorado, testers established persistent access on an internal developer workstation after exploiting a misconfigured automation service. To sustain command-and-control without triggering perimeter defenses, they configured a low-bandwidth outbound channel designed to blend into infrastructure traffic that is routinely permitted through egress controls. Security operations later identified periodic outbound communication from the compromised host to a single unfamiliar external endpoint not associated with approved vendors or user activity. The traffic was distributed over time rather than bursty. Although the exchanges resembled legitimate service requests, packet inspection revealed irregular payload sizing and structured encoding patterns inconsistent with typical client behavior across the environment. What covert communication technique was most likely used to sustain the red team's access?

- TCP Sequence Tunneling
- HTTP/S Tunneling
- DNS Tunneling
- ICMP Tunneling

54. At a petrochemical processing facility in Corpus Christi, Texas, a certified ethical hacker performs an authorized reconnaissance assessment within the manufacturing zone. The objective is to identify programmable controllers

responsible for automated production processes. The tester initiates a targeted scan against a TCP service commonly used by industrial controllers that support structured function-code exchanges for reading and writing memory areas. Multiple field devices respond to this service, confirming the presence of automation controllers communicating over that port. Based on this reconnaissance pattern, what type of OT device scan is being performed?

- Scanning Omron PLC devices
- Scanning Modbus devices
- Scanning Siemens SIMATIC S7 PLCs
- Capturing Modbus/TCP traffic using Wireshark

55. A fintech startup in Austin, Texas authorizes a controlled red team engagement to evaluate the resilience of its web-based loan management platform. At the outset of the engagement, the assessment team concentrates on developing a structural understanding of the application. They examine publicly exposed endpoints, observe server responses under different navigation paths, identify accessible directories, and document the relationships between client-side scripts, form parameters, and backend behaviors. Error handling patterns and response variations are cataloged to understand how user interactions are processed across various components of the platform. The collected information is used to guide strategic planning for subsequent phases of the engagement. Within the web application hacking methodology, which phase is most accurately demonstrated in this scenario?

- Reconnaissance
- Gaining Access
- Maintaining Access
- Scanning

56. Anthony works as a security consultant for a financial services firm in Chicago, Illinois. During an internal engagement, he reviews traffic logs and observes repeated connection attempts to a service that appears to provide

directory-related information beyond a single domain. The responses suggest that the underlying database contains entries representing objects across the entire organization rather than being limited to a single segment. As Anthony continues his assessment, he notices that administrators commonly connect to this service when troubleshooting directory-related issues. The service listens on a dedicated port and allows object searches across multiple domains without requiring prior knowledge of the specific domain name. Which service is Anthony most likely enumerating?

- Lightweight Directory Access Protocol (TCP/UDP 389)
- Session Initiation Protocol (TCP/UDP 5060, 5061)
- Global Catalog Service (TCP/UDP 3268)
- Microsoft RPC Endpoint Mapper (TCP/UDP 135)

57. A city utility billing portal in Raleigh, North Carolina includes a search field used to retrieve customer records. During an authorized penetration test, an assessor submits repeated instances of a character commonly interpreted within SQL statements as part of the input value. The application does not display detailed error messages, yet certain submissions result in irregular response behavior and partial rendering of results. The tester suspects the input may be affecting how the SQL command is internally constructed. Which black-box testing technique is being applied?

- Using right square bracket characters to detect identifier handling issues
- Sending isolated quotation characters to detect unsanitized input
- Sending arbitrary data to detect truncation issues
- Sending special characters to detect SQL modification behavior

58. An internal audit at a pharmaceutical research company in San Diego, California, revealed that a directory server was reachable from a restricted testing subnet. Security analyst Daniel Harper initiated a basic directory query using simple authentication to validate connectivity. The query succeeded, confirming that the server was responding to unauthenticated search requests.

To understand the structural layout of the directory before performing deeper queries, Daniel needed to retrieve the base-level naming context entries exposed by the server. His objective was to identify the root domain components and configuration partitions before constructing targeted search filters. Which command should Daniel execute to obtain the directory naming context information?

- `ldapsearch -x -h -b "DC=htb,DC=local" "objectclass=*"`
- `ldapsearch -h -x -s base namingcontexts`
- `ldapsearch -h -x -b "DC=htb,DC=local"`
- `ldapsearch -h -x`

59. An internal review at a financial analytics firm in Minneapolis, Minnesota, uncovered unusual query patterns directed at the company's directory services infrastructure. Security engineer Olivia Grant examined the logs and discovered that a user account had been issuing structured directory queries to retrieve lists of user objects, group memberships, and organizational units. Further inspection revealed that the account was able to access information about privileged groups containing the word "Admin" in their titles. The activity did not involve password guessing or authentication bypass, but rather systematic directory lookups to map internal user and group relationships. What type of enumeration is illustrated in this scenario?

- DNS Enumeration
- SMTP Enumeration
- VoIP Enumeration
- LDAP Enumeration

60. A municipal services portal in Lexington, Kentucky includes a search parameter that retrieves citizen service requests. During an authorized security review, an analyst alters the parameter value by introducing single quotation marks, logical expressions such as `AND 1=1`, and variations like `AND 1=2`, observing how the application responds to each modification. By comparing

differences in the application's output and behavior after each structured input change, the analyst evaluates whether the parameter affects the underlying query processing. Which SQL injection detection method is being applied?

- Static Testing
- Function Testing
- Dynamic Testing
- Fuzz Testing

61. A financial services firm detects that outbound corporate emails containing sensitive underwriting data were intercepted while transmitted over unsecured channels. To immediately restore confidentiality and ensure authenticity of executive communications, the security operations team deploys a standardized email encryption framework compatible with the organization's Microsoft Outlook environment. The selected solution must support digital signatures for sender authentication, rely on a public-key infrastructure for secure key exchange, and enable recipients to validate signed messages using certificates issued by trusted authorities. Identify the email encryption standard that best fulfills these requirements.

- S/MIME
- OpenPGP
- FlowCrypt
- RMail

62. An enterprise organization in Chicago deploys a WPA2-Enterprise wireless network integrated with a centralized authentication server to validate user credentials through 802.1X. A security consultant is tasked with assessing the resilience of the authentication workflow. While monitoring wireless traffic near the facility, the consultant captures a successful authentication exchange between a legitimate employee device and the authentication infrastructure. Instead of attempting to derive credentials or modify packet contents, the consultant retransmits portions of the previously observed authentication

messages to the network under controlled conditions. The access point processes the retransmitted authentication sequence in a manner that suggests acceptance of reused authentication data rather than rejecting it as stale or duplicated. Identify the wireless attack technique demonstrated in this assessment.

- Data Frame Injection
- RADIUS Replay Attack
- Bit-Flipping Attack
- Initialization Vector Replay Attack

63. A digital forensics consultant in Portland, Oregon examines an iPhone seized as part of a corporate data leakage investigation. The device contains third-party extensions and system modifications not typically permitted by the operating system vendor. The owner explains that whenever the device is powered off and restarted, it boots normally and remains fully functional for everyday tasks such as calls and messaging. However, the custom extensions and system-level tweaks do not function until a specific jailbreak application installed on the device is manually executed. No external computer is required during this reactivation process. Determine the type of jailbreaking technique implemented on this device.

- Tethered Jailbreaking
- Semi-Untethered Jailbreaking
- Semi-Tethered Jailbreaking
- Untethered Jailbreaking

64. During an authorized wireless security assessment, an ethical hacker captures traffic between client devices and a corporate access point to evaluate the strength of the implemented encryption mechanism. Packet analysis reveals that before protected data exchange begins, the client and access point complete a structured four-message key negotiation process. Subsequent traffic is encrypted using an AES-based counter mode protocol that integrates message

authentication for integrity protection. Based on these observations, identify the wireless encryption standard deployed on the network.

- WPA2
- WPA
- WPA3
- WEP

65. A regional hospital network is conducting incident containment after discovering that an internal file server was accessed by unauthorized actors. While forensic analysis is ongoing, a security engineer must immediately protect sensitive medical records stored on a mounted partition without shutting down the system. The solution must support strong encryption (including 256-bit AES), allow creation of encrypted containers within existing storage volumes, and provide the capability to conceal protected data inside standard-looking volumes to reduce visibility during continued investigation. Select the disk encryption tool that best satisfies these operational and security requirements.

- FileVault
- BitLocker Drive Encryption
- Rohos Disk Encryption
- VeraCrypt

66. A technology consulting firm in Portland, Oregon began experiencing repeated topology recalculations across its switching infrastructure. Shortly after a newly connected device came online in a conference room, spanning-tree convergence events were triggered across multiple distribution switches. Engineers determined that the access-layer interface connected to that device was influencing path-selection decisions, introducing a more favorable bridge priority value into the environment and affecting the established hierarchy. To preserve the intended switching structure and prevent unauthorized devices from altering root selection decisions, which control should be employed?

- Applying Root Guard on designated interfaces

- Enabling BPDU Guard on edge ports
- Activating UDLD (Unidirectional Link Detection) on uplinks
- Configuring Loop Guard on non-designated ports

67. At a biomedical analytics firm in Raleigh, North Carolina, security consultant Marcus Ellison was reviewing exposed services on a legacy Linux host located in a screened subnet. While mapping available services, he observed that the machine was responding to time synchronization queries from multiple internal systems. Curious whether the service might reveal additional intelligence, Marcus issued targeted queries against the time service and received responses that exposed internal client addresses and system identifiers interacting with it. The information provided unexpected visibility into internal network structure without requiring authentication. From the available options, what enumeration technique is illustrated in this scenario?

- NFS Enumeration
- NTP Enumeration
- SNMP Enumeration
- NetBIOS Enumeration

68. During a red team engagement at a biotechnology firm in San Diego, California, the security team observed that a compromised internal workstation was generating an unusually high number of outbound name resolution requests to external servers. Upon deeper inspection, analysts discovered that the query strings contained encoded data segments rather than typical lookup patterns. Further analysis revealed that these outbound requests were being used to transfer sensitive information to an attacker-controlled system outside the corporate network. Which technique was most likely used to covertly transfer the data in this scenario?

- TCP Parameter Manipulation
- Reverse ICMP Tunnel
- Reverse HTTP Shell

- DNS Tunneling

69. In a high-stakes cybersecurity exercise in Boston, Emily, an ethical hacker, is tasked with tracing a mock phishing email sent to a healthcare provider's staff. Using the email header, she identifies a series of IP addresses and server details, including multiple timestamps and server names. Her objective is to pinpoint the exact moment the email was processed by the sender's system. As part of her reconnaissance, what specific detail from the email header should Emily examine to determine this information?

- Date and time of message sent
- Sender's mail server
- Authentication system used by sender's mail server
- Date and time received by the originator's email servers

70. A mid-sized manufacturing firm in Des Moines, Iowa reported that several employee workstations were periodically communicating with an unfamiliar external server over an IRC channel. The affected systems showed no visible interface for remote control, yet investigators confirmed that the machines were receiving instructions and executing distributed traffic bursts at scheduled intervals. Further review revealed that the initial infection occurred after employees opened a phishing email attachment. Once executed, the infected systems silently connected outward and began awaiting commands from a centralized remote controller. Determine the Trojan classification that best matches this behavior.

- Backdoor Trojan
- Botnet Trojan
- E-banking Trojan
- Rootkit Trojan

71. A security consultant is performing an authorized assessment of a regional healthcare provider's patient portal in Portland, Oregon. During testing, he observes that authenticated users are assigned session identifiers embedded

within URL parameters after login. To evaluate the robustness of the session management implementation, he initiates multiple authentication requests in rapid succession using controlled test accounts. He then compares the issued identifiers and notices that although parts of the value remain constant, certain segments change in a predictable progression over time. By analyzing the incremental pattern across a controlled batch of issued identifiers generated within the same time window, he is able to anticipate future valid identifiers without capturing traffic from other users. Which token prediction mechanism best explains the weakness identified in this scenario?

- Weak Random Number Generator (PRNG)
- Small Token Space
- Timestamp-based Tokens
- Sequential Tokens

72. A threat intelligence review at a manufacturing firm in Pittsburgh, Pennsylvania, revealed repeated external queries targeting the organization's public name servers. Although no intrusion occurred, analysts observed that the queries appeared designed to systematically map internal naming conventions and infrastructure patterns. The security team determined that the issue was not excessive traffic volume but rather the exposure of internal namespace details through responses handled by the same server used for both internal and external resolution. To reduce the risk of disclosing sensitive structural information to outside systems, the team redesigned their DNS deployment. Which countermeasure best addresses the risk described in this scenario?

- Enabling DNS logging and anomaly detection
- Implementing a split DNS architecture
- Implementing rate limiting on DNS servers
- Randomizing DNS source ports and query identifiers

73. A regional healthcare provider in Phoenix began experiencing intermittent outages affecting its patient portal. Network monitoring showed an abrupt surge

of traffic consisting of short, stateless datagrams directed at random service ports across multiple edge-facing servers. Unlike connection-oriented attacks, there was no evidence of incomplete handshakes or abnormal session buildup. Instead, the attack traffic simply consumed available upstream capacity through sheer packet volume, preventing legitimate users from reaching the web platform. Based on the observed behavior, determine the most likely attack technique.

- UDP flood attack
- Ping of Death attack
- ICMP flood attack
- NTP amplification attack

74. During an authorized security assessment of a smart home product manufacturer in San Jose, California, a certified ethical hacker evaluates the web-based management interface used to configure connected IoT cameras and lighting controllers. The tester discovers that when an internal user visits a specially crafted external website, the browser automatically initiates requests to a locally hosted device management interface within the user's private network. Which attack technique best explains this behavior?

- Forged Malicious Device Attack
- SDR-Based Attack
- DNS Rebinding Attack
- Distributed Denial-of-Service (DDoS) Attack

75. As part of an authorized security assessment at a maritime logistics firm in Charleston, South Carolina, an ethical hacker evaluated the organization's resilience to coordinated endpoint compromise. Employees received a carefully crafted email attachment disguised as a routine operational update. After execution on several systems, monitoring tools later revealed that the infected machines periodically contacted an external host controlled by the tester. Over time, the compromised systems began receiving commands from a centralized

control server and simultaneously generated coordinated network traffic toward designated targets when instructed, without any direct user interaction. From a malware classification standpoint, what component is being simulated in this scenario?

- Scareware
- Spyware
- Potentially Unwanted Applications (PUAS)
- Botnet Agents

76. A security consultant is conducting an authorized assessment for a healthcare billing provider in Phoenix, Arizona. While monitoring internal traffic, he observes an authenticated employee interacting with a sensitive web-based management portal over TCP. During the session, the consultant carefully crafts and injects packets into the ongoing communication stream. Shortly afterward, the legitimate user experiences irregular responses from the application, and the server begins processing commands originating from the consultant's injected traffic as though they were part of the established session. The technique does not involve credential guessing or forcing the user to reauthenticate. Instead, it targets the communication channel already in progress. From a network-level perspective, what type of session hijacking technique is being demonstrated?

- TCP/IP Hijacking
- UDP Hijacking
- Blind Hijacking
- RST Hijacking

77. During an internal security review at a transportation authority in Columbus, Ohio, a red team analyst positioned himself on the same local network segment as several domain-joined administrative workstations. Over several hours, he recorded authentication exchanges as legitimate users performed their routine logon activities across the network. He later analyzed the captured traffic to recover valid credentials associated with privileged accounts. Based on the

attacker's actions, how should this password attack be classified?

- Passive Online Attack
- Non-Electronic Attack
- Active Online Attack
- Offline Attack

78. A regional law firm authorizes a wireless resilience evaluation after employees report intermittent connectivity disruptions in conference rooms. An ethical hacker assigned to the assessment analyses client behaviour while transmitting carefully crafted 802.11 management frames toward the organization's primary access point. Each transmission immediately causes several connected laptops to lose association with the network, requiring users to reconnect manually. Connectivity interruptions occur only when the crafted frames are sent. Identify the wireless attack illustrated by this activity.

- Deauthentication Attack
- Jamming Attack
- Evil Twin Attack
- Eavesdropping Attack

79. *A state benefits processing platform in Sacramento, California, implemented a multi-step identity verification process before granting access to sensitive citizen records. During a controlled assessment, security analyst Daniel Kim observed that by altering specific request parameters within the transaction sequence, it was possible to bypass an intermediate verification stage and retrieve restricted account data. Further analysis revealed that the authentication workflow advanced through sequential client-driven interactions, but the server did not enforce strict validation of completion for each required stage before granting access. Based on the scenario, which vulnerability classification best describes the issue identified?*

- Design Flaws
- Application Flaws

- *Poor Patch Management*
- *Misconfigurations / Weak Configurations*

80. A large online retail platform in Seattle, Washington, maintains continuous telemetry of inbound network flows to detect abnormal surges that may indicate a distributed denial-of-service condition. During a recent monitoring exercise, the security engineering team implemented a statistical mechanism that continuously evaluates streaming traffic metrics and mathematically determines the exact point at which normal behavior shifts into an anomalous state. Rather than comparing traffic against static baselines or clustering historical profiles, the system dynamically identifies the precise moment when distribution characteristics deviate beyond an established threshold. This approach is designed to flag sudden structural changes in traffic behavior in near real time, even if the overall traffic volume appears similar to prior peaks. Which detection technique is being applied in this scenario?

- Traffic Pattern Analysis
- Wavelet-Based Signal Analysis
- Activity Profiling
- Sequential Change-Point Detection

81. A payroll management portal used by a manufacturing firm in Toledo, Ohio allows administrators to configure customizable notification templates that are later incorporated into automated reporting functions. During an authorized assessment, an ethical hacker submits specially structured input into a template field while creating a test notification. The application accepts and stores the value without any noticeable disruption to the interface. Days later, when a scheduled reporting task executes, the resulting dataset includes records beyond the expected scope defined by the report criteria. Further review reveals that the reporting engine dynamically constructs database queries using previously stored template values during execution. Determine the SQL injection variant illustrated in this scenario.

- Piggybacked Query Injection

- Error-Based SQL Injection
- Stored Procedure Injection
- Second-Order SQL Injection

82. Several months prior to a confirmed compromise, security telemetry at a semiconductor manufacturer in Phoenix, Arizona showed systematic intelligence gathering focused on executive leadership, research engineers, and publicly exposed infrastructure. Subsequent investigation determined that the adversary had assembled customized exploit frameworks, tested malware variants against commercial defensive products in isolated environments, and mapped externally accessible services associated with the organization. These activities were part of a coordinated strategy developed well before any credential abuse or lateral movement was observed. Determine the APT lifecycle stage represented by these actions.

- Expansion
- Persistence
- Preparation
- Initial Intrusion

83. A mid-sized insurance provider in Hartford, Connecticut authorizes a controlled red team engagement to evaluate its public-facing customer portal. Before progressing to active exploitation, the assessment team concentrates on understanding how the site is organized and how its content is interconnected. Using automated tooling, they systematically retrieve publicly accessible pages along with associated resources such as scripts, media files, and referenced directories. The collected material allows the team to analyze navigation paths, hidden references, and structural relationships without repeatedly interacting with the live production system. This preparatory effort is intended to build a detailed structural understanding of the application before later testing phases begin. Within the web server attack methodology, which stage is most accurately demonstrated in this scenario?

- Web Server Footprinting

- Website Mirroring
- Information Gathering
- Vulnerability Scanning

84. Olivia works as a senior red team specialist at SecureMatrix Labs in Portland, Oregon. During a controlled adversarial simulation, she deployed a stealth persistence mechanism on a test workstation to evaluate advanced defensive detection capabilities. After rebooting the system, the operating system continued to function normally, but subsequent investigation revealed that the OS was executing within an underlying control layer established before full system initialization. This layer intercepted low-level CPU instructions and mediated direct hardware interactions prior to their delivery to the operating system. Which type of rootkit best describes the mechanism deployed in this scenario?

- Boot-Loader-Level Rootkit
- Kernel-Level Rootkit
- Hypervisor-Level Rootkit
- Application-Level/User-Mode Rootkit

85. A financial services provider in Frankfurt, Germany, experienced intermittent service disruption affecting its public-facing transaction portal. Network engineers observed a surge of connection attempts targeting the web servers. Packet inspection revealed that the majority of incoming traffic consisted of connection initiation requests that were never completed. The servers allocated memory and maintained half-open connection states while waiting for acknowledgments that never arrived. Over time, the connection table reached capacity, preventing legitimate users from establishing new sessions. No abnormal payloads were detected, and the packets themselves appeared structurally valid. Which attack technique best explains this behavior?

- Fragmentation attack
- ACK flood attack

- SYN flood attack
- Spoofed session flood attack

86. During a penetration test, an analyst repeatedly initiates TCP connections to a target host and records the sequence numbers returned in the SYN/ACK responses. By examining predictable or incremental patterns in these values, the analyst attempts to infer characteristics of the underlying operating system. What OS fingerprinting attribute is being analyzed in this scenario?

- Time to Live (TTL)
- TCP Window Size
- Initial Sequence Number (ISN)
- TCP Timestamp Analysis

87. Following reports of inconsistent IP-to-MAC mappings on an internal access switch at a manufacturing company in Detroit, Michigan, the network security team enabled additional validation controls. Soon afterward, the switch began automatically discarding certain ARP replies that did not match previously recorded IP address assignments. Log entries indicated that packets were being denied due to validation failures tied to existing address-to-port mappings learned earlier from legitimate host configuration traffic. Which switch-level security feature is most likely responsible for enforcing this ARP validation behavior?

- Configuring BPDU Guard to protect spanning-tree topology
- Enabling DHCP Snooping to track address assignments
- Activating Dynamic ARP Inspection to validate ARP packets
- Displaying the DHCP Snooping binding table for verification

88. An organization authorizes a wireless penetration test to evaluate the resilience of its WPA2-protected network. The assigned ethical hacker prepares the wireless adapter for packet capture and begins monitoring traffic from a nearby access point. To accelerate the assessment, the tester transmits crafted 802.11 frames that momentarily interrupt active client connections. Shortly

afterward, new authentication exchanges are observed in the capture logs, providing the necessary material for subsequent analysis. The activity described corresponds to which component of the Aircrack-ng suite?

- aireplay-ng
- airmon-ng
- airodump-ng
- aircrack-ng

89. At a private aerospace research facility in Mesa, Arizona, an executive raises concerns after sensitive discussion points from speakerphone meetings begin surfacing externally. The device shows no indicators of active audio recording, and application permission history does not reflect recent camera or microphone authorization changes. A forensic mobile analysis identifies that an installed application has been continuously reading motion sensor output while the phone's loudspeaker is active. The collected sensor data was later transmitted to a remote server, where acoustic characteristics were reconstructed from the recorded measurements. Identify the attack technique responsible for this compromise.

- Spearphone Attack
- Camfecting
- Storm Breaker Abuse
- Android Camera Hijack Attack

90. A smart building management company in Seattle, Washington deploys wireless door sensors and badge-based access systems throughout its corporate headquarters. During a security assessment, an analyst captures legitimate radio transmissions between employee access badges and the entry control units. Later that evening, without modifying or decrypting the original communication, the analyst retransmits the previously captured signal toward a secured entrance. The access control system accepts the transmission as valid and unlocks the door, even though the legitimate badge is not present.

Determine the attack technique demonstrated in this assessment.

- Rolling Code Attack
- BlueBorne Attack
- Replay Attack
- Sybil Attack

91. As part of an internal security assessment at First Union Bank in Chicago, Rachel Morgan is evaluating whether unauthorized packet capture tools are operating within the loan processing segment of the network. During traffic observation, she notices behavior suggesting that a particular host may be processing frames beyond its intended destination scope. To verify whether the network interface is accepting traffic not explicitly addressed to it, Rachel decides to transmit specially crafted packets designed to provoke an abnormal response from a system operating in promiscuous mode. Which detection technique should Rachel use to confirm the presence of a sniffer?

- Ping method by sending packets with an incorrect MAC address
- Sniffer detection using an NSE script to check for promiscuous mode
- ARP method by sending non-broadcast ARP requests
- DNS method by monitoring reverse DNS lookup traffic

92. A healthcare analytics firm in Denver, Colorado hosts several internal applications on an IIS web server. During an authorized security assessment, a tester evaluates a lesser-used endpoint designed for administrative operations. By sending crafted HTTP requests directly to this endpoint, the tester is able to invoke server-side management functions without interacting with the standard login workflow presented by the primary user interface. Further review indicates that certain restricted operations can be executed when accessed through alternate request paths, suggesting inconsistent enforcement of access controls within the application. Which IIS vulnerability is most accurately demonstrated in this scenario?

- File and directory permissions vulnerability

- Trust boundary violation vulnerability
- CRLF cross-site scripting vulnerability
- Authentication bypass vulnerability

93. During an executive-level incident review at HarborTech Industries in Baltimore, Maryland, analysts categorize key elements of a recent intrusion. They identify the organization that orchestrated the attack, document the malicious infrastructure used to reach internal systems, outline the technical approach employed to exploit weaknesses, and specify which internal business unit was affected. Within the Diamond Model of Intrusion Analysis, which element represents the technical approach used to carry out the attack?

- Capability
- Victim
- Infrastructure
- Adversary

94. A regional healthcare provider in Portland, Oregon, recently migrated its patient scheduling portal to a new cloud platform. Within days, multiple patients reported that when searching online for the clinic's appointment system, they were directed to a website that looked identical to the official portal. The fraudulent page appeared prominently in search engine results and prompted users to log in using their patient credentials. The URL closely resembled the legitimate domain name, and no internal DNS servers had been altered within the organization's infrastructure. Security analysts later determined that the attacker had created a convincing replica of the portal and manipulated search visibility so that unsuspecting users would voluntarily navigate to the malicious site. Which type of social engineering technique best explains this attack?

- Spimming
- Spear Phishing
- Pharming
- Whaling

95. Upon completing a vulnerability evaluation for a financial services firm in Cincinnati, Ohio, the security team finalized its formal report for executive review. One portion of the document grouped identified weaknesses into severity tiers and highlighted systems with elevated exposure levels across the environment. This part of the report emphasized the relative impact and prioritization of identified weaknesses across affected assets. Which component of the vulnerability assessment report is represented in this scenario?

- Findings
- Risk Assessment
- Assessment Overview
- Recommendations

96. During an authorized cloud security assessment for an e-commerce company based in Seattle, Washington, a certified ethical hacker gains temporary programmatic access to the organization's cloud account. The tester focuses on identifying permission boundaries by querying the account to determine which identity entities are associated with attached policies and what level of access those identities possess across cloud resources. The objective is to understand privilege relationships before attempting any further controlled actions. Which cloud reconnaissance activity best aligns with this effort?

- Enumerating S3 Buckets
- Enumerating EC2 Instances
- Enumerating Serverless Resources
- Enumerating IAM Roles

97. Natalie Brooks is leading an authorized red team exercise for Sentinel Networks in Seattle. While briefing her team on different attacker profiles, she describes an individual who is new to cybersecurity, actively learning techniques through online communities, and experimenting with basic tools on low-risk targets to build practical skills without causing significant damage. Which hacker class best matches this profile?

- Red Hat hacker
- Blue Hat hacker
- Green Hat hacker
- Gray Hat hacker

98. As part of a controlled red-team engagement, an ethical hacker evaluates the resilience of a corporate campus against radio-frequency disruption. The tester activates a portable multi-antenna signal suppression device from a nearby building. The interference affects wireless communication across several departments within an estimated coverage radius of approximately 120 meters. The disruption persists for slightly over an hour before the device requires recharge. Analysis confirms that multiple frequency bands, including Wi-Fi and cellular standards, were simultaneously impacted. Based on the operational characteristics observed, identify the jamming device most consistent with this activity.

- CPB-2920 Jammer
- PCB-4510 Jammer
- CPB-2612H-5G Jammer
- PCB-1016 Jammer

99. While conducting a compliance-driven security assessment at a public healthcare data center in Maryland, Jason, a senior penetration tester, was asked to reconcile outdated asset documentation for several legacy network appliances still active within the environment. Internal records lacked accurate device identifiers, administrative contact entries, and interface-level statistics needed for regulatory reporting. Preliminary testing revealed that the devices were still exposing management information through long-standing read-only credentials configured years earlier. Rather than logging into each device manually or passively observing traffic, Jason decided to use a command-line approach that would systematically traverse the exposed management object tree of each system and redirect the complete output into a file for automated processing. Determine which tool aligns with this requirement.

- SnmpWalk
- SoftPerfect Network Scanner
- Nmap
- Wireshark

100. Arjun Mehta, a red team specialist at Sentinel Dynamics, is conducting a controlled reconnaissance assessment against the company's perimeter network. During testing, the security operations team observes that the firewall logs display several different originating systems associated with the same scanning activity. Arjun's objective is to ensure that his actual testing machine cannot be easily distinguished from other recorded entries. What technique is Arjun using in this scenario?

- Source Routing
- Source Port Manipulation
- IP Address Decoy
- IP Address Spoofing

101. An authorized security assessment is performed on a public-sector services portal in Madison, Wisconsin. After authenticating with a controlled test account, the assessor captures the authentication identifier issued by the application. Under controlled lab conditions, she attempts to reuse the captured identifier from a separate machine connected through a different encrypted channel. Although the identifier remains valid and within its lifetime, the application rejects the request when presented from the alternate environment. Analysis indicates that the server evaluates characteristics associated with the original secure exchange before allowing continued use of the issued identifier. Which defensive mechanism most likely explains this behavior?

- Applying IPsec protection at the network layer
- Enforcing HTTP Strict Transport Security
- Cryptographically binding authentication tokens to the TLS connection context

- Encrypting DNS resolution traffic using DNS over HTTPS

102. A telecommunications provider in Toronto operates a monitoring platform that analyzes inbound traffic streams during suspected denial-of-service conditions. The system converts traffic measurements into signal components and evaluates their energy across multiple frequency ranges to distinguish abnormal traffic bursts from background network noise. Rather than focusing on traffic baselines or identifying the exact statistical breakpoint where behavior changes, the platform identifies anomalies by decomposing traffic signals into spectral components for analysis. Which DDoS detection technique is being used in this scenario?

- Traffic Pattern Analysis
- Sequential Change-Point Detection
- Wavelet-Based Signal Analysis
- Activity Profiling

103. A subscription-based analytics platform in Portland, Oregon provides enterprise clients with API access to project dashboards. Each dashboard is associated with a unique identifier included in client-side API requests when retrieving project data. While evaluating access controls, a security analyst signs in using a standard user account and captures a legitimate API request used to retrieve a specific project dashboard. By altering only the identifier value within the request and replaying it through the same authenticated session, the analyst receives data belonging to a different client organization. The session remains valid, and no elevated privileges are granted. The behavior indicates that access validation does not adequately verify whether the requesting user is authorized to access the referenced resource. Identify the OWASP API security risk illustrated in this scenario.

- Broken Object Property Level Authorization
- Broken Object Level Authorization (BOLA)
- Broken Function Level Authorization

- Broken Authentication

104. A national retail chain headquartered in Minneapolis, Minnesota operates a customer rewards portal supported by front-end delivery layers designed to improve performance during peak shopping periods. During an authorized security assessment, a tester submits a specially crafted request containing unusual header combinations and a modified query parameter while accessing a promotional page. Shortly afterward, other legitimate users requesting the same promotional page through standard browsers begin receiving altered content that differs from what the application normally generates. When the tester accesses the underlying origin system directly, the response reflects the expected legitimate version. After some time and additional routine traffic, the unexpected content is no longer served. Identify the attack technique best explains this observed behavior?

- DNS Rebinding Attack
- SQL Injection Vulnerability
- Web Cache Poisoning Attack
- DNS Server Hijacking

105. In Miami, Florida, cybersecurity analyst Laura Bennett is investigating unauthorized access incidents affecting Sunshine Credit Union's online banking platform. Audit logs reveal that compromised accounts consistently involve users who accessed the portal through specially crafted links sent via email. The links direct victims to the legitimate website, where they proceed to authenticate successfully. Shortly afterward, unauthorized access to the same accounts is observed without any additional credential guessing or brute-force activity. Further examination shows that a value associated with the user's interaction with the application remains unchanged throughout the authentication process and can be introduced before the user completes sign-in. Which countermeasure should Laura implement to prevent this type of account takeover?

- Regenerate the session ID after a successful login

- Use restrictive cache directives such as "Cache-Control: no-cache"
- Do not create sessions for unauthenticated users
- Implement SSL to encrypt all information in transit via the network

106. A technology consulting firm in Charlotte, North Carolina experienced a targeted intrusion after an employee interacted with a carefully crafted phishing email. Security analysts reconstructed the sequence of events and determined that once the email attachment was opened, built-in scripting utilities were invoked to inject malicious instructions into an active system process. No standalone malicious executables were discovered on disk. The injected instructions began running directly inside legitimate processes before any registry modifications or task scheduling changes were observed. At this point in the attack sequence, which operational phase of the fileless attack lifecycle is being demonstrated?

- Persistence
- Code Execution
- Point of Entry
- Achieving Objectives

107. A network administrator reviews logs and observes that an attacker sends packets requesting the target system's internal clock value. The response includes timing information that can be used to calculate round-trip delay and analyze host characteristics. What host discovery technique is being used in this scenario?

- IP Protocol Scan
- ICMP Timestamp Ping Scan
- ICMP ECHO Ping Sweep
- UDP Ping Scan

108. A cybersecurity firm in Reston, Virginia is contracted to investigate a cluster of endpoint alerts affecting multiple employees of a satellite communications

manufacturer. The affected employees all work in orbital systems engineering and regularly access a specialized industry forum used for regulatory updates and technical advisories. Security logs indicate that each compromised workstation visited the same trusted industry website shortly before establishing unusual outbound connections. The site continues to operate normally for general visitors. Further analysis shows that a recently added script conditionally loads additional content only when specific environmental attributes—such as originating organization and browser profile—match predefined conditions. The observed activity stems from routine browsing of a site frequently visited by professionals within that sector. Which web application attack category best describes this technique?

- Watering Hole Attack
- JavaScript Hijacking
- Magecart Attack
- Cross-Site Scripting (XSS)

109. A digital media company in Seattle, Washington deploys an Nginx-based infrastructure to support its internal analytics dashboard and content publishing portal. During an authorized red team engagement, a tester evaluates the web-based administrative interface used to upload configuration bundles and manage application components. While analyzing a file-upload feature, the tester observes that certain user-supplied parameters submitted with uploaded content are incorporated into backend processing routines with limited validation. By adjusting specific values in the request, he alters how the server-side component interprets those inputs. Subsequent log analysis shows that the modified input affected system-level operations executed under the web service context, despite no direct shell access being obtained. Which Nginx-related vulnerability best describes the weakness identified in this scenario?

- Server-side request forgery (SSRF) vulnerability
- Improper certificate validation
- OS command injection in nginxWebUI

- NULL pointer dereference in HTTP/3

111. A financial institution in Chicago deploys an internal HTTPS-based customer portal that uses response compression to optimize bandwidth. During an authorized security assessment, a tester gains a vantage point along the communication path between internal clients and the gateway device. By repeatedly initiating controlled requests and analyzing subtle differences in encrypted response sizes, the tester correlates variations in compressed output with specific input patterns. Over time, this analysis enables extraction of portions of a protected authentication value transmitted within the secure channel. Which session hijacking technique best describes this activity?

- Man-in-the-Browser (MITB) attack
- Man-in-the-Middle (MITM) attack
- CRIME attack
- Forbidden attack

112. During a compliance audit at a logistics company in Columbus, Ohio, the mobile security team discovers that several field-issued Android devices are responding to remote commands from an unknown external system. The affected devices are not connected via USB, and no enterprise mobility policies were recently modified. Network monitoring reveals that the devices have remote debugging enabled and are accepting connections over the wireless network on a specific high-numbered port commonly associated with remote device communication. Investigators determine that the external system was able to capture screenshots, list installed applications, forward ports, and install additional packages without requiring physical access to the devices. Which attack technique most accurately explains this compromise?

- ADB Exploitation via TCP 5555
- Device Administration API Abuse
- Android Rooting
- FRP Bypass

113. A logistics technology provider in Kansas City, Missouri conducts an internal review after an ethical hacker demonstrates several recurring input-handling weaknesses across different customer-facing web applications. The findings show that validation logic varies between modules, with many controls implemented inconsistently across components developed by separate teams. Although immediate patches are applied to address the identified flaws, similar issues have surfaced in previous platform iterations despite corrective updates. Leadership determines that isolated fixes are insufficient and initiates an effort to standardize how security requirements are defined and incorporated across future development initiatives. Based on the web application attack countermeasures, which category best aligns with this remediation approach?

- Security Misconfiguration
- Broken Access Control
- Insecure Design
- Cryptographic Failures / Sensitive Data Exposure

114. Granite Ridge Technologies in New Jersey is preparing to formalize its information security governance model. Executive leadership requires adoption of an internationally recognized framework that ensures confidentiality, integrity, and availability of information while enabling the organization to systematically identify, assess, and manage information security risks. The framework must also support compliance with regulatory and contractual obligations and demonstrate commitment to stakeholders. Which standard best fulfills these requirements?

- ISO/IEC 27001:2022
- ISO/IEC 27701:2019
- ISO/IEC 27002:2022
- ISO/IEC 27005:2022

115. A financial clearinghouse in Newark, New Jersey, initiated a structured vulnerability review across its enterprise servers. The scanning platform was

configured to collect detailed information about installed updates, local security configurations, and system policy settings on each target machine. The resulting report contained granular host-level findings, including configuration inconsistencies and patch gaps that required direct system-level inspection to obtain. Based on the activity described, what type of vulnerability scanning is being performed?

- Non-Credentialed Scanning
- Application Scanning
- Automated Scanning
- Credentialed Scanning

116. A national e-commerce retailer experiences a sustained distributed attack that saturates its edge connectivity with high-volume traffic originating from thousands of globally dispersed hosts. Internal mitigation attempts such as ACL tuning and rate limiting fail to restore service stability. After escalating the issue, the organization coordinates with its upstream connectivity provider, which begins rerouting inbound traffic through a large-scale filtering infrastructure capable of absorbing and scrubbing malicious traffic before forwarding legitimate requests back to the retailer's network. What defensive approach is being applied in this scenario?

- Implementing RFC3704 filtering at the network edge
- Enabling Cisco IPS Source IP reputation filtering
- Deploying Black Hole filtering at the routing layer
- Leveraging DDoS prevention offerings from an ISP or DDoS mitigation service

117. A regional healthcare provider in Minneapolis, Minnesota began experiencing intermittent connectivity issues across a newly activated access-layer network segment. Shortly after a contractor connected a diagnostic device to an unused switch port, multiple employee workstations failed to receive valid network configurations. System logs showed repeated address negotiation

attempts from affected hosts, while monitoring tools recorded a rapid sequence of configuration requests originating from a single switch interface. Within minutes, additional clients on the segment encountered similar assignment failures. From a sniffing standpoint, which technique most accurately explains this behavior?

- DHCP Starvation
- Rogue DHCP Server
- IRDP Spoofing
- MAC Spoofing

118. During an internal assessment, a penetration tester sends specially crafted TCP packets to a target system without initiating a standard three-way handshake. Packet captures show that when these probes reach closed ports, the host responds with a TCP RST segment. However, when the probes reach open ports, the host does not return any response. Further inspection of the probe structure reveals that the packets contain an uncommon combination of TCP control bits rather than a single flag. What scanning technique is being performed?

- XMAS Scan
- UDP Scan
- FIN Scan
- TCP Connect Scan

119. A fintech startup in Austin, Texas deploys several virtual machines within a public cloud environment. During an authorized cloud security assessment, a tester uploads a small script to one of the instances through a web application vulnerability. After executing the script locally on the instance, the tester retrieves temporary access credentials associated with the instance's assigned role. These credentials are then used to enumerate storage resources and access additional cloud services within the same account. Which cloud attack technique best corresponds to this activity?

- Wrapping Attack
- Cloud Snooper Attack
- CPDoS Attack
- IMDS Attack

120. A private equity firm in Minneapolis, Minnesota allows employees to access internal reporting tools from their personally owned smartphones under its BYOD program. During a routine security assessment, a consultant observes that when an employee leaves their unlocked phone unattended, a colleague can immediately open the firm's financial application and review client investment records without any additional verification step inside the application. The operating system itself requires a passcode to unlock the device, but once unlocked, corporate applications open directly to sensitive dashboards. Identify the BYOD security guideline that would directly mitigate this exposure.

- Use encryption mechanism to store data
- Maintain a clear separation between business and personal data
- Set passwords for apps to restrict others from accessing them
- Set a strong passcode on the device and change it relatively often

121. During an internal investigation at a healthcare billing firm in Denver, Colorado, the security team analyzes suspicious activity involving a senior accountant's corporate smartphone. The user reports that the device behaved normally and that no links were clicked or applications installed during the timeframe in question. Telecom monitoring reveals that the device received several binary-formatted SMS messages shortly before the incident. These messages were not visible in the messaging application. Within minutes of receiving them, the phone began transmitting cellular location identifiers and device-related data to an unfamiliar external system. The transmissions occurred automatically and did not require any user interaction. Which mobile attack technique most accurately explains this behavior?

- Call Spoofing
- SMiShing
- SIMjacker
- DTP Hijacking

122. A large-scale inventory management platform implements a pattern-based inspection layer to prevent malicious database interactions. During authorized testing, repeated payloads containing recognizable structural sequences are denied before reaching the application logic. While analyzing the inspection behavior, the tester observes that blocked requests share a consistent textual arrangement of components. The tester then alters how those components are presented within the payload while preserving the intended database operation. After this adjustment, the request bypasses the inspection layer and executes successfully, producing results consistent with earlier attempts. Determine the evasion method that best accounts for this behavior.

- Constructing the payload dynamically through segmented string operations
- Introducing inline comment delimiters to fragment instruction sequences
- Transforming literal parameters using alternate character encoding schemes
- Modifying spacing and delimiter placement to disrupt detection patterns

123. During a red team assessment of a multinational financial firm, you're tasked with identifying key personnel across various departments and correlating their digital footprints to evaluate exposure risk. Your objective includes mapping user aliases across platforms, identifying geotagged media, and pinpointing potential insider threats based on social posting behavior. The team has shortlisted multiple tools for the task. Considering the technical capabilities and limitations described in the approved reconnaissance toolkit, which tool provides cross-platform username correlation by scanning hundreds of social networking sites, but does not natively support geolocation tracking or visualizing identity relationships?

- Social Searcher
- Sherlock
- Creepy
- Maltego

124. During a red team engagement against a multinational financial services organization, an ethical hacker conducts network reconnaissance against externally accessible systems. Instead of sending scan traffic directly from the originating assessment machine, the tester routes all reconnaissance packets through an intermediary external system before they reach the target network. When the organization's security team reviews monitoring data, the activity appears to originate from infrastructure unrelated to the tester's actual geographic or organizational location. From a reconnaissance methodology perspective, what is the primary objective of using this intermediary system?

- To conceal the origin of reconnaissance activity and reduce attribution risk
- To establish persistent access within the target network
- To bypass authentication controls protecting internal applications
- To spoof packet source addresses at the IP layer

125. A media streaming company in Los Angeles, California engages a certified ethical hacker to evaluate the resilience of its cloud-hosted infrastructure. After initial access is obtained through an exposed credential in a development repository, the tester systematically modifies logging configurations, establishes alternate access keys for persistence, and documents privilege relationships between services within the tenant. The tester's actions are focused on maintaining continued access and mapping the internal structure of the environment after initial compromise has occurred. Within the cloud attack lifecycle, which phase best represents this stage of activity?

- Post-Exploitation
- Information Gathering

- Exploitation
- Vulnerability Assessment

題 號	解答 (Correct Answer)
1	Obfuscation
2	Combinator Attack
3	Nikto
4	External Scanning
5	Hoax Letters that spread false security warnings
6	SOA
7	Corporate Espionage
8	Stateful Multilayer Inspection Firewall
9	Sequential Change-Point Detection
10	True Positive
11	Impersonation

題 號	解答 (Correct Answer)
12	HTTP Response-Splitting Attack
13	FIN, PUSH and URG scan on port 80
14	Exposed Bearer Tokens in Logs
15	Inference-Based Assessment
16	ntpq -p [host]
17	Agent Smith
18	Repackaging Legitimate Apps after modifying their internal structure
19	Key Reinstallation Attack (KRACK)
20	Metamorphic Virus
21	51% Attack
22	Elicitation

題 號	解答 (Correct Answer)
23	High-interaction Honeypot
24	LDAP Injection
25	MAC Flooding
26	Identification of Hover Mismatch URLs in the embedded link
27	Insecure Ecosystem Interfaces
28	Use an Intrusion Detection System (IDS)
29	Artifact wiping
30	HTTP/2 Stream Memory Not Reclaimed on RST
31	Clone Phishing
32	Command and Control
33	Golden SAML Attack

題 號	解答 (Correct Answer)
34	RSA
35	Container Escape
36	Information warfare
37	Injecting malicious records through DNS Cache Poisoning
38	Encrypt stored data with quantum-resistant algorithms
39	Footprinting through Social Networking Sites
40	Network/port scanning
41	Wrapper
42	--spoof-mac 0
43	Ciphertext-only attack
44	MODBUS

題 號	解答 (Correct Answer)
45	Maintaining Access
46	Hardware Keylogger
47	Fileless Malware
48	Signature Recognition
49	WSDL Probing Attacks
50	Performing Heavy Query-Based Blind SQL Injection
51	Transforming query structure to evade pattern-based inspection
52	Detect
53	DNS Tunneling
54	Scanning Modbus devices
55	Reconnaissance

題號	解答 (Correct Answer)
56	Global Catalog Service (TCP/UDP 3268)
57	Sending special characters to detect SQL modification behavior
58	ldapsearch -h -x -s base namingcontexts
59	LDAP Enumeration
60	Dynamic Testing
61	S/MIME
62	RADIUS Replay Attack
63	Semi-Untethered Jailbreaking
64	WPA2
65	VeraCrypt
66	Applying Root Guard on designated interfaces

題 號	解答 (Correct Answer)
67	NTP Enumeration
68	DNS Tunneling
69	Date and time received by the originator's email servers
70	Botnet Trojan
71	Sequential Tokens
72	Implementing a split DNS architecture
73	UDP flood attack
74	DNS Rebinding Attack
75	Botnet Agents
76	TCP/IP Hijacking
77	Passive Online Attack

題 號	解答 (Correct Answer)
78	Deauthentication Attack
79	Design Flaws
80	Sequential Change-Point Detection
81	Second-Order SQL Injection
82	Preparation
83	Web Server Footprinting
84	Hypervisor-Level Rootkit
85	SYN flood attack
86	Initial Sequence Number (ISN)
87	Activating Dynamic ARP Inspection to validate ARP packets
88	aireplay-ng

題號	解答 (Correct Answer)
89	Spearphone Attack
90	Replay Attack
91	Ping method by sending packets with an incorrect MAC address
92	Authentication bypass vulnerability
93	Capability
94	Pharming (或視不同題庫版本為 Search Engine Phishing)
95	Risk Assessment
96	Enumerating IAM Roles
97	Green Hat hacker
98	CPB-2920 Jammer
99	SnmpWalk

題 號	解答 (Correct Answer)
100	IP Address Decoy
101	Cryptographically binding authentication tokens to the TLS connection context
102	Wavelet-Based Signal Analysis
103	Broken Object Level Authorization (BOLA)
104	Web Cache Poisoning Attack
105	Regenerate the session ID after a successful login
106	Code Execution
107	ICMP Timestamp Ping Scan
108	Watering Hole Attack
109	OS command injection in nginxWebUI

題號	解答 (Correct Answer)
110	(無此題)
111	CRIME attack
112	ADB Exploitation via TCP 5555
113	Insecure Design
114	ISO/IEC 27001:2022
115	Credentialed Scanning
116	Leveraging DDoS prevention offerings from an ISP or DDoS mitigation service
117	DHCP Starvation
118	XMAS Scan
119	IMDS Attack

題 號	解答 (Correct Answer)
120	Set passwords for apps to restrict others from accessing them
121	SIMjacker
122	Modifying spacing and delimiter placement to disrupt detection patterns
123	Sherlock
124	To conceal the origin of reconnaissance activity and reduce attribution risk
125	Post-Exploitation